

AI在徐医 — 开发记录

版本: v3.0
最后更新: 2026年6月12日
受众: 开发团队、技术评审

1. 项目背景

徐州医科大学内部 AI 资讯与智能助手平台。高校师生对 AI 技术认知有限，需要一个低门槛的一站式入口：浏览 AI 资讯、获取文章解读、订阅推送、使用 AI 问答。

项目代号 ai_web ，内部部署，日活 100-200 人。

2. 技术选型与理由

2.1 后端: Node.js + Express 5 + TypeScript

选择	理由
Node.js + Express	团队最熟悉的技术栈；API 层轻量无需 Spring 的重量；Express 5 原生支持 async error handling
TypeScript	类型安全优于运行时错误，特别是数据库查询和 API 入参
pg 无 ORM	查询简单（大部分是 CRUD），ORM 增加学习成本和性能开销；原生 SQL 更可控
Zod 4	编译时类型 + 运行时校验二合一，API 入参校验的核心工具

2.2 前端: Vue 3 + Vite + Tailwind CSS 4

选择	理由
Vue 3 Composition API	组合式函数天然适合 KeepAlive 和响应式状态共享
Vite	开发体验（HMR < 1s）远超 Webpack

Tailwind CSS 4	原子化 CSS，适合小团队快速迭代 UI
Pinia	Vue 3 官方推荐的状态管理，TS 支持好

2.3 AI: DeepSeek + PageAgent

选择	理由
DeepSeek	性价比高，中文能力强，支持 user_id 参数实现 KVCache 隔离
PageAgent 架构	阿里开源的页面级 Agent 模式：将页面上下文 + 用户问题 + 站内检索结果组合发给 LLM

2.4 数据库: PostgreSQL

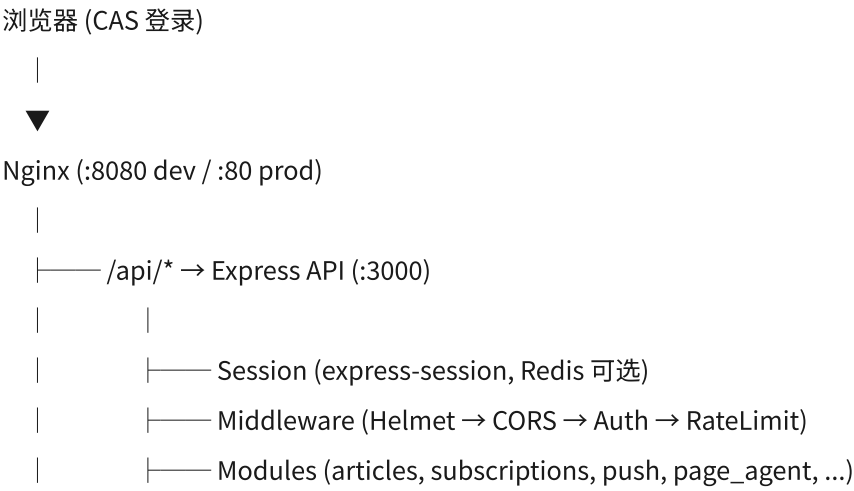
选择	理由
PostgreSQL	高校内网已有 Postgres 实例；JSONB 支持用户画像等半结构化数据

2.5 部署: Docker Compose (开发) + Systemd (生产)

- 开发环境用 Docker Compose 一键启动 (API + Web + Nginx)
- 生产环境用 Systemd 管理进程生命周期，利用 journald 统一日志

3. 架构设计

3.1 整体架构



```
|      |—— Jobs (node-cron: push, profile analysis, birthday)
|      |
|      |—— PostgreSQL (主库)
|      |—— Oracle (用户同步, 只读)
|      |—— DeepSeek API (PageAgent + 画像分析)
|      |—— 企业微信 API (推送 + 标签同步)
|
|—— /* → Vue SPA (:5173 dev / dist prod)
```

3.2 请求生命周期

1. Nginx 接收请求 → proxy_pass 到 API 或 Web
2. Helmet 设置安全头
3. CORS 校验来源
4. express-session 解析会话
5. requireAuth 中间件校验登录态
6. rate_limit 中间件限流
7. Zod 校验请求体
8. 业务逻辑处理
9. JSON 响应 + 结构化日志

3.3 前端路由

```
/      → ArticlesPage    (首页, 资讯列表)
/articles/:id → ArticleDetailPage (文章详情)
/push-digests/today → TodayPushDigestPage (今日推送)
/subscription → SubscriptionPage (订阅管理)
/admin        → AdminPage    (内容管理)
/admin/publish → AdminPublishPage (文章发布)
/admin/stats   → AdminStatsPage (统计看板)
/admin/birthday → AdminBirthdayPage (生日推送管理)
/admin/feedback-review → FeedbackReviewPage (反馈审批)
/ai-lab        → AiLabPage    (AI 试验场)
/profile        → ProfilePage  (个人中心)
/ranking        → RankingPage  (排行榜)
/feedback-public → FeedbackPublicPage (反馈墙, 免登录)
```

4. 模块设计

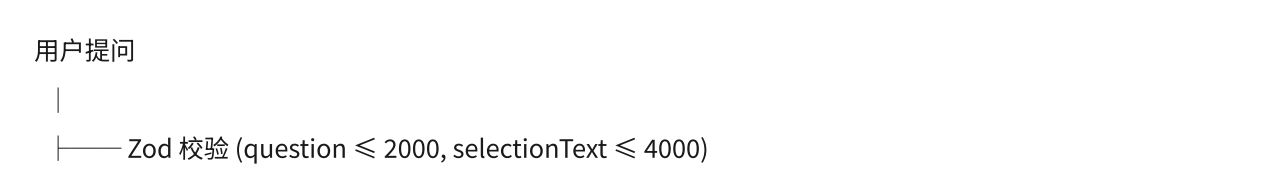
4.1 业务模块一览

模块	路径	职责
auth	modules/auth/cas.ts	CAS 单点登录/回调/登出
articles	modules/articles/	文章 CRUD、AI 优化、URL 提取、JWT 发布
channels	modules/channels/	频道分类管理
subscriptions	modules/subscriptions/	用户订阅管理、推送频率配置
push	modules/push/	企微推送、标签同步、消息模板
page_agent	modules/page_agent/	PageAgent 对话、上下文构建、画像分析、PII 脱敏
feedback	modules/feedback/	用户反馈收集与查询
stats	modules/stats/	统计看板数据聚合
aixy	modules/aixy/	AI 知识库对话代理
profile	modules/profile/	个人中心数据
users	modules/users/	用户信息查询
birthday	modules/birthday/	生日推送卡片生成
wecom	modules/wecom/	企微客户端（Token 管理、消息发送）

4.2 PageAgent 模块详解

PageAgent 是系统最复杂的模块，负责将页面上下文 + 用户问题 + 历史对话 + 用户画像组合为 LLM 请求。

数据流:



- 鉴权 (requireAuth)
- 限流 (20次/分钟)
- |
- sanitizeForModel (PII 脱敏)
- 加载对话历史 (最近 8 条)
- 加载用户画像 (personaPrompt, preferenceSummary)
- 站内文章检索 (关键词触发)
- |
- buildPageAgentMessages → system prompt + 画像 + 历史 + 用户 prompt
- |
- axios → DeepSeek API (stream: true)
- |
- normalizeAiContent (剥离 <think> 标签)
- sanitizeForModel (输出 PII 脱敏)
- 无效回答检测 (< 10 字符 / 空壳确认)
- |
- SSE → 前端 DOMPurify 渲染

安全措施（2026-06-12 加固）：

措施	位置	说明
提示词注入防护	prompts.ts	System prompt 追加安全约束 + <user_query> 标签隔离
personaPrompt 硬校验	profile_service.ts	注入关键词检测 + 格式校验，不合格退回 fallback
PII 脱敏（入向）	sanitize.ts	手机号/邮箱/身份证/银行卡/IP/姓名 → [REDACTED]
PII 脱敏（出向）	service.ts	LLM 输出经 sanitizeForModel 后再返回
错误信息脱敏	service.ts	不暴露模型名和 API 错误详情
用户 ID 哈希	user_id_hash.ts	HMAC-SHA256 后发送给 DeepSeek

4.3 定时任务

任务	Cron	说明
----	------	----

每日推送 (1)	0 20 * * *	每晚 20:00
每日推送 (2)	0 11 * * *	每天 11:00
每周推送	0 20 * * 0	每周日 20:00
标签同步	0 5 * * *	每天 00:05 (默认)
画像分析	0 3 * * 0	每周日凌晨 3:00
生日推送	每天 10:00	通过 node-cron 调度
Oracle 用户同步	每天凌晨	通过 node-cron 调度

5. 安全设计

5.1 认证与授权

CAS 单点登录

- |
- |—— 登录: redirect → CAS /login → CAS /callback → session.user
- |—— 登出: destroy session → redirect CAS /logout
- |
- |—— Session 配置:
 - httpOnly: true
 - sameSite: lax
 - secure: true (生产)
 - maxAge: 8 小时

中间件层级:

中间件	适用场景
requireAuth	所有需要登录的接口
requireAdmin	管理后台操作
requireAdminOrInternalToken	内部服务调用或管理员

requireInternalToken	纯内部服务调用
----------------------	---------

5.2 输入校验

- 所有 API 入参通过 Zod Schema 校验（类型 + 长度 + 格式）
- `express.json({ limit: "1mb" })` 限制请求体大小
- PageAgent 输入在发送给 LLM 前经 `sanitizeForModel` PII 脱敏

5.3 输出安全

- 前端 `DOMPurify 3.4.0` 清洗所有 LLM 输出的 HTML
- PageAgent 输出经 `sanitizeForModel` PII 脱敏
- 错误信息不暴露内部配置

5.4 基础设施

防护层	实现
HTTP 安全头	<code>helmet ^8.1.0</code>
CORS	限定 web origin
速率限制	PageAgent: 20次/分钟/用户
SQL 注入	<code>pg</code> 参数化查询（100% 覆盖）
XSS	<code>DOMPurify</code> 前端清洗

6. 开发规范

6.1 目录约定

- 每个业务模块一个目录，包含 `routes.ts`
- 路由前缀 `/api/<module>`，在 `app.ts` 统一挂载
- 鉴权在路由层通过中间件控制，不在业务逻辑里散落

6.2 数据库操作

- 直接用 `pg Pool` 写 SQL，参数化查询
- Schema 变更通过 `db.ts` 中 `ALTER TABLE ... ADD COLUMN IF NOT EXISTS`

- 类型泛型: query<MyRow>("SELECT ...", [param])

6.3 环境变量

- 所有配置在 config/env.ts 集中定义
- .env 不入库
- 新增变量同时更新 env.ts 和 .env.example

6.4 日志

- 使用结构化日志 (logger.info/error/debug)
- 日志 key 使用点分隔命名: page.agent.answer.start

6.5 提交规范

fix: <简述> # Bug 修复
feat: <简述> # 新功能
refactor: <简述> # 重构
style: <简述> # UI/样式
chore: <简述> # 杂项

6.6 分支策略

- main — 生产分支
- feature/<描述> — 功能开发
- fix/<描述> — Bug 修复

7. 安全加固记录

2026-06-12 安全加固 (commit: 63b53ed)

审查范围: PageAgent 全链路 (routes → service → prompts → sanitize → frontend)

已确认的安全防护 (加固前):

防护	状态
Helmet HTTP 安全头	☑

CORS 限定 origin	☒
Session httpOnly/sameSite/secure	☒
Zod 入参校验（类型+长度）	☒
requireAuth 全路由鉴权	☒
会话所有权校验	☒
Rate Limit 20次/分钟	☒
PII 脱敏（入向）	☒
DOMPurify 3.4.0 前端 XSS	☒
PostgreSQL 参数化查询	☒
用户 ID HMAC 哈希	☒

发现的缺口及修复:

Gap	严重程度	修复
提示词注入无防护	☒ 严重	System prompt 追加安全约束 + <user_query> XML 标签隔离
personaPrompt 可注入	☒ 严重	注入关键词正则检测 + 格式硬校验
LLM 输出未 PII 脱敏	☒ 中等	sanitizeForModel() 作用于 finalAnswer
错误信息泄露模型名	☒ 中等	用户端不暴露 errorDetail 和 env.deepseekModel

2026-06-12 Git 仓库瘦身

- 从历史中移除 12 个 PSD 源文件（~170MB）
 - .git 从 219MB → 21MB（缩减 90%）
 - GitHub zip 下载从 ~130MB → ~15MB
-

8. 已知限制与改进方向

8.1 当前限制

限制	影响	改进方向
单进程 Node.js	无法利用多核	PM2 cluster 模式
内存限流	进程重启后限流计数丢失	Redis 集中存储
Session 内存存储	无法多实例共享	Redis store
无 CI/CD	手动部署	GitHub Actions
无自动化测试	回归风险	Playwright E2E 全覆盖
日志仅本地 journald	排查需登服务器	ELK/Loki 集中收集

8.2 待实现功能

- ☐ PageAgent 多轮对话上下文窗口管理（防止超出 Token 限制）
- ☐ 文章推荐算法优化（基于用户画像的协同过滤）
- ☐ 移动端 PWA 支持
- ☐ 多语言支持（留学生群体）
- ☐ AI 回答质量自动评估
- ☐ 推送打开率统计

9. 依赖清单

后端 (apps/api/package.json)

包	版本	用途
express	^5.x	Web 框架
helmet	^8.1.0	安全头
cors	^2.x	跨域
express-session	^1.x	会话管理

pg	^8.x	PostgreSQL 驱动
zod	^4.3.6	入参校验
axios	^1.x	HTTP 客户端
node-cron	^3.x	定时任务
dotenv	^16.x	环境变量
oracledb	^6.x	Oracle 连接（用户同步）

前端 (apps/web/package.json)

包	版本	用途
vue	^3.x	前端框架
vue-router	^5.x	路由
pinia	^2.x	状态管理
tailwindcss	^4.x	CSS 框架
marked	^18.0.0	Markdown 渲染
dompurify	^3.4.0	XSS 清洗
axios	^1.x	HTTP 客户端
lucide-vue-next	^0.x	图标库

10. 变更日志

日期	版本	变更
2026-06-12	v3.0	PageAgent 安全加固 (63b53ed) + Git 瘦身 + 文档生成
2026-06-12	v2.x	SSE 流式回答、错误分级、反馈系统、生日推送
2026-05-28	v1.x	初始版本上线：资讯浏览、PageAgent 问答、订阅推送、管理后台